

# ASHAKids | Auditoría B02 del backend

**Corte 2026-10-09-14: adopción de ashakids\_runtime en Supabase.** Fecha: 9 de octubre de 2026, America/Lima. Evaluación técnica asistida; no pentest, certificación clínica ni despliegue público.

Repositorio: <https://github.com/sromansilva/ashakids-platform> . Rama: piero-dev. SHA de implementación/guiones auditado: dd71407a8e21f0bacf6904bf430784d1c3b26dda, V22\_Seguridad\_BD\_Rol\_Backend. Base: V21/e756e7b5865201c2a0bd311786746d20b940449f. V22 está publicado y verificado en dev y feat/piero-dev. Las fuentes backend/app permanecen como en V20/b76a34a; el cambio efectivo es el rol/ACL/RLS de BD y DATABASE\_URL privada. Un SHA Git no incluye credenciales ni demuestra por sí solo el estado de Supabase.

Entorno: Windows, Python 3.13.7, FastAPI/SQLAlchemy/asyncpg del corte13, PostgreSQL 17.6 real en Supabase. Destino host/puerto/BD conservado; TLS 1.3 con CERT\_REQUIRED y validación de hostname. Candidato FastAPI ASGI en proceso, después HTTP real en la API habitual 127.0.0.1:8000. No nueva instancia8001, BD descartable, TRUNCATE, borrado físico ni modificación de cuentas/datos clínicos anteriores. ADMIN bootstrap solo inició/cerró sus sesiones para crear las cuentas nuevas autorizadas.

## 01. Dictamen ejecutivo

**B02 aplicado, verificado y adoptado en este clon. Valoración técnica: 86/100, frente a 83/100 del corte13.** Se separó la cuenta técnica de FastAPI del propietario. El rol nuevo carece de privilegios administrativos y sus accesos coinciden con el inventario aprobado. El candidato pasó antes de cambiar la conexión; el recorrido HTTP posterior confirmó persistencia, permisos por recurso y revocación. ADMIN de AshaKids mantiene sus funciones. HTTPS/hosting, rotación de cuentas anteriores y recuperación siguen pendientes.

| Criterio / máximo             | Corte13 | Actual | Fundamento y límite                                                                                                                                                        |
|-------------------------------|---------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Funciones y persistencia / 30 | 28      | 28     | Núcleo y variantes repetidos con rol nuevo. DELETE físicos y aceptación visual exhaustiva sin ensayo.                                                                      |
| Modelo y conexión / 15        | 15      | 15     | TLS válido/negativo, metadatos reales,19 modelos sin diferencias. No nuevos cambios estructurales.                                                                         |
| Seguridad y permisos / 20     | 13      | 16     | Rol sin administración/bypass/propiedad, ACL exactas y políticas dirigidas al runtime. PUBLIC defaults y autorización de familias en FastAPI; hosting/rotación pendientes. |
| Operación y publicación / 15  | 9       | 9      | Adopción local verificada y V22 publicado. No hosting público ni prueba de restauración/caída.                                                                             |
| Validaciones y errores / 10   | 9       | 9      | Variantes422/409 y revocación repetidas; guardas previas conservadas. No todas las variantes de cada payload.                                                              |
| Pruebas y mantenimiento / 10  | 9       | 9      | SQL real y dos cohortes,114 unidades reejecutadas en este corte y guiones reproducibles. Sin carga, suite destructiva ni nueva QA visual.                                  |
| Total / 100                   | 83      | 86     | Valoración técnica, no calificación oficial ni porcentaje de cobertura.                                                                                                    |

| Indicador         | Resultado nuevo                                                                                             | Alcance                                                                          |
|-------------------|-------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|
| Rol PostgreSQL    | LOGIN; seis atributos administrativos/INHERIT false;0 pertenencias y0 objetos propios                       | ADMIN/PADRE/TERAPEUTA de AshaKids no se alteran.                                 |
| Permisos/RLS      | 22 tablas;58 políticas;16 secuencias USAGE                                                                  | RLS permanece activa en26 tablas; no políticas TO PUBLIC.                        |
| Denegaciones SQL  | 6 casos42501 esperados                                                                                      | Sin DML destructivo, setval ni TRUNCATE; EXPLAIN sin ANALYZE.                    |
| Candidato         | 99 respuestas ASGI esperadas,0 fallos                                                                       | FastAPI y SQL reales; transporte en proceso antes de adopción.                   |
| API8000 posterior | 99 núcleo+29 complemento+5 sistema=133 casos HTTP registrados,0 fallos                                      | 53/55 operaciones con respuesta positiva. Lecturas auxiliares fuera del cómputo. |
| Persistencia      | Cada cohorte:2 reservas,2 sesiones finalizadas,1 reporte completo,2 mensajes;0 sesiones auth nuevas activas | READ ONLY, guardas por IDs/marker y reporte idéntico tras relogin.               |
| Backend           | 114 aprobadas,0 fallos/omisiones;19 avisos                                                                  | Selección sin BD/conftest. No toda la suite.                                     |
| Frontend          | Sin cambios de fuente ni nueva ejecución                                                                    | 257 componentes+25 rutas/tipos/check/build del corte13 son evidencia heredada.   |

No se suman resultados previos como pruebas nuevas. En este corte hay99 casos candidatos y133 casos finales, con transportes y cohortes distintos. Las garantías se limitan a los recorridos ensayados. Las19 advertencias corresponden a deprecaciones Starlette/httpx/cookies; no son fallos de permisos.

## 02. Arquitectura y cambios realizados

React -> HTTP/JSON -> FastAPI -> servicios/Pydantic -> SQLAlchemy/asyncpg -> PostgreSQL. Se conservan autenticación propia, Argon2id, sesiones opacas hasheadas y cookie HttpOnly. Sin Supabase Auth ni conexión SQL desde React. ADR0010 documenta la separación entre rol de aplicación y rol PostgreSQL del backend; ADR0009/TLS y limitador se conservan.

El inventario aprobado está en scripts/b02\_role\_inventory.py. apply\_b02\_runtime\_role aplica CREATE ROLE, CONNECT de la BD configurada, USAGE de public y grants por tabla en una transacción. Crea políticas por operación exclusivamente TO ashakids\_runtime y USAGE solo en secuencias dependientes de tablas con INSERT. Aborta si el rol existe; no es una migración automática al arrancar FastAPI. La contraseña aleatoria se deriva a un verificador SCRAM para el DDL; ningún secreto se publica.

| Grupo de tablas                                                                | Acceso aprobado y comprobado   | Límite                                                        |
|--------------------------------------------------------------------------------|--------------------------------|---------------------------------------------------------------|
| usuarios, sesiones_autenticacion, pacientes, perfiles                          | SELECT, INSERT, UPDATE, DELETE | DELETE en contratos protegidos; ejecución física sin ensayo.  |
| usuario_rols, administradores                                                  | SELECT, INSERT, DELETE         | Sin UPDATE ni administración de roles PostgreSQL.             |
| tutores, terapeutas                                                            | SELECT, INSERT, UPDATE, DELETE | Edición de cuentas nuevas probada; no identidades anteriores. |
| expedientes, tratamientos, reservas, sesiones, reportes_sesion, conversaciones | SELECT, INSERT, UPDATE         | No eliminación de historial clínico/chat.                     |
| mensajes, auditoria_cambios                                                    | SELECT, INSERT                 | Sin UPDATE/DELETE.                                            |
| roles, logros, perfil_logros, actividades, resultados_nivel, evaluaciones_ia   | SELECT                         | Sin escrituras de catálogo/educativas nuevas.                 |
| mundos, niveles, objetivos, mensaje_adjuntos                                   | Sin permisos de tabla          | Fuera del inventario actual. No GRANT ALL.                    |

SELECT/DELETE usan USING true; INSERT usa WITH CHECK true; UPDATE usa ambas. Esas políticas habilitan al servidor para aplicar sus reglas y **no aíslan familias dentro de PostgreSQL**. FastAPI sigue validando sesión, rol y pertenencia/asignación de cada recurso. El runtime no tiene propiedad, CREATE en BD/public, TRUNCATE, REFERENCES, TRIGGER, MAINTAIN ni UPDATE/SELECT de secuencias. ADMIN de AshaKids conserva cuentas, pacientes y tratamientos.

Se leyeron26 tablas/RLS,92 restricciones,71 índices y26 dependencias de secuencias en metadatos reales;19 modelos ORM no muestran diferencias. Las columnas visibles por information\_schema para el rol nuevo son154, correspondientes a las tablas concedidas; no se reinterpretan las178 del propietario en corte13 como un resultado nuevo equivalente. No se añadieron tablas, columnas, índices o restricciones clínicas.

### 03. APIs verificadas: identidad y pacientes

A=ADMIN, P=PADRE, T=TERAPEUTA, Prop=cuenta propia. En clínica se exige pertenencia/asignación. L=live-journey.json, F=live-followup.json, S=adoption-system.json. La matriz refleja casos finales HTTP; el candidato separado está en candidate-journey.json. operation-matrix.json conserva actor, caso, esperado, obtenido y referencia individual. Confirmar requiere A/T; cancelar admite el participante autorizado.

| Método y ruta                                         | Rol        | Caso / esperado-obtenido / evidencia             |
|-------------------------------------------------------|------------|--------------------------------------------------|
| POST /api/v1/auth/login                               | Público    | Escritura; esperado=obtenido: 200. F,L.          |
| POST /api/v1/auth/logout                              | Token opc. | Escritura; esperado=obtenido: 200. F,L.          |
| GET /api/v1/auth/me                                   | Sesión     | Lectura; esperado=obtenido: 200, 401. F,L,S.     |
| GET /api/v1/padres/me                                 | P          | Lectura; esperado=obtenido: 200. L.              |
| GET /api/v1/padres/hijos                              | P          | Lectura; esperado=obtenido: 200. F.              |
| POST /api/v1/padres/hijos                             | P          | Escritura; esperado=obtenido: 201, 422. L.       |
| GET /api/v1/padres/hijos/{id_paciente}                | P          | Lectura; esperado=obtenido: 200. F.              |
| PATCH /api/v1/padres/hijos/{id_paciente}              | P          | Escritura; esperado=obtenido: 200. L.            |
| DELETE /api/v1/padres/hijos/{id_paciente}             | P          | DELETE físico sin ensayo: fuera de autorización. |
| PATCH /api/v1/padres/hijos/{id_paciente}/inactivar    | P          | Escritura; esperado=obtenido: 200. F.            |
| GET /api/v1/terapeutas/me                             | T          | Lectura; esperado=obtenido: 200. L.              |
| GET /api/v1/admin/me                                  | A          | Lectura; esperado=obtenido: 200. L.              |
| GET /api/v1/admin/cuentas                             | A          | Lectura; esperado=obtenido: 200. F.              |
| GET /api/v1/admin/cuentas/{id_usuario}                | A          | Lectura; esperado=obtenido: 200. F.              |
| PATCH /api/v1/admin/cuentas/{id_usuario}              | A          | Escritura; esperado=obtenido: 200. F.            |
| DELETE /api/v1/admin/cuentas/{id_usuario}             | A          | DELETE físico sin ensayo: fuera de autorización. |
| POST /api/v1/admin/cuentas/padres                     | A          | Escritura; esperado=obtenido: 201, 422. L.       |
| POST /api/v1/admin/cuentas/terapeutas                 | A          | Escritura; esperado=obtenido: 201, 422. L.       |
| PATCH /api/v1/admin/cuentas/{id_usuario}/suspender    | A          | Escritura; esperado=obtenido: 200. L.            |
| PATCH /api/v1/admin/cuentas/{id_usuario}/activar      | A          | Escritura; esperado=obtenido: 200. L.            |
| GET /api/v1/admin/cuentas/{id_usuario}/hijos          | A          | Lectura; esperado=obtenido: 200. F.              |
| PATCH /api/v1/admin/pacientes/{id_paciente}/reactivar | A          | Escritura; esperado=obtenido: 200. F,L.          |
| GET /api/v1/usuarios                                  | A          | Lectura; esperado=obtenido: 200. F.              |
| POST /api/v1/usuarios                                 | A          | Escritura; esperado=obtenido: 201, 422. L.       |

| Método y ruta                            | Rol     | Caso / esperado-obtenido / evidencia       |
|------------------------------------------|---------|--------------------------------------------|
| GET /api/v1/usuarios/{key}               | A       | Lectura; esperado=obtenido: 200. L.        |
| PATCH /api/v1/usuarios/{key}             | A/Prop. | Escritura; esperado=obtenido: 200. F.      |
| GET /api/v1/pacientes                    | A/P/T   | Lectura; esperado=obtenido: 200. F.        |
| POST /api/v1/pacientes                   | A/P     | Escritura; esperado=obtenido: 201, 422. L. |
| GET /api/v1/pacientes/{key}              | A/P/T   | Lectura; esperado=obtenido: 200, 404. F,L. |
| PUT /api/v1/pacientes/{key}              | A/P     | Escritura; esperado=obtenido: 200. L.      |
| DELETE /api/v1/pacientes/{key}           | A/P     | Escritura; esperado=obtenido: 200. L.      |
| GET /api/v1/pacientes/{key}/tratamientos | A/P/T   | Lectura; esperado=obtenido: 200. F.        |
| POST /api/v1/tratamientos                | A       | Escritura; esperado=obtenido: 201. L.      |

Las altas de ADMIN/PADRE/TERAPEUTA, ambas familias de pacientes, edición y estados se probaron exclusivamente sobre IDs nuevos. El cambio de contraseña y la suspensión revocaron sesiones; reactivar no revivió tokens. El acceso de otra familia o terapeuta no asignado devuelve404. El bootstrap existente no se editó ni suspendió; sus sesiones se cerraron.

## 04. APIs verificadas: citas, sesiones, mensajería y sistema

| Método y ruta                              | Rol     | Caso / esperado-obtenido / evidencia            |
|--------------------------------------------|---------|-------------------------------------------------|
| GET /api/v1/citas                          | A/P/T   | Lectura; esperado=obtenido: 200. F.             |
| POST /api/v1/citas                         | A/P/T   | Escritura; esperado=obtenido: 201, 409. L.      |
| GET /api/v1/citas/{key}                    | A/P/T   | Lectura; esperado=obtenido: 200, 404. F,L.      |
| PUT /api/v1/citas/{key}                    | A/P/T   | Escritura; esperado=obtenido: 200. L.           |
| PATCH /api/v1/citas/{key}/estado           | A/P/T   | Escritura; esperado=obtenido: 200, 403. L.      |
| GET /api/v1/sesiones                       | A/P/T   | Lectura; esperado=obtenido: 200. F.             |
| POST /api/v1/sesiones                      | A/T     | Escritura; esperado=obtenido: 201, 409. L.      |
| GET /api/v1/sesiones/{key}                 | A/P/T   | Lectura; esperado=obtenido: 200, 404. F,L.      |
| POST /api/v1/sesiones/{key}/iniciar        | A/T     | Escritura; esperado=obtenido: 200, 409. L.      |
| POST /api/v1/sesiones/{key}/cerrar         | A/T     | Escritura; esperado=obtenido: 200, 409. L.      |
| GET /api/v1/sesiones/{key}/reporte         | A/P/T   | Lectura; esperado=obtenido: 200, 404. L.        |
| PUT /api/v1/sesiones/{key}/reporte         | A/T     | Escritura; esperado=obtenido: 200, 422. L.      |
| GET /api/v1/sesiones/{key}/reporte/pdf     | A/P/T   | Lectura; esperado=obtenido: 200, 404. L.        |
| GET /api/v1/conversaciones/contactos       | P/T     | Lectura; esperado=obtenido: 200. F.             |
| GET /api/v1/conversaciones                 | P/T     | Lectura; esperado=obtenido: 200. L.             |
| POST /api/v1/conversaciones                | P/T     | Escritura; esperado=obtenido: 200. L.           |
| GET /api/v1/conversaciones/{key}           | P/T     | Lectura; esperado=obtenido: 200, 403, 404. F,L. |
| GET /api/v1/conversaciones/{key}/mensajes  | P/T     | Lectura; esperado=obtenido: 200. L.             |
| POST /api/v1/conversaciones/{key}/mensajes | P/T     | Escritura; esperado=obtenido: 201, 422. L.      |
| GET /                                      | Público | Lectura; esperado=obtenido: 200. S.             |
| GET /health                                | Público | Lectura; esperado=obtenido: 200. S.             |
| GET /health/ready                          | Público | Lectura; esperado=obtenido: 200. S.             |

Con sesiones auth distintas por solicitud concurrente: reserva201/409 y una sola cita; sesión201/409 y una sola sesión por cita; inicio/cierre200/409 y repetición409. Reportes: dos200, un reporte completo con último escritor A/B; sin control optimista de versión. Chat: dos200 con el mismo ID nuevo y dos mensajes persistentes. Dos solicitudes acotadas por carrera, no prueba de carga.

Reprogramación, confirmación profesional, inicio anticipado409, inasistencia temprana409/final NO\_ASISTIO, límites422 y aislamiento404 pasaron. ADMIN recibió403 en chat privado. PDF familiar válido, completo y con datos sintéticos; relogin recuperó el mismo reporte. /health/ready obtuvo200 con SELECT1 real. Los429/503 y HTTPS se comprobaron en unidades con dobles; no se apagó Supabase ni se hizo fuerza bruta o despliegue final.

## 05. APIs no verificadas y capacidades pendientes

No hubo respuestas inesperadas en los casos registrados. 401/403/404/409/422 y42501 esperados son protecciones correctas. Los dos DELETE físicos no se invocaron; se mantienen contratos y comprobaciones de dependencias, sin declararlos certificados. La desactivación lógica de pacientes nuevos sí pasó y se reactivó el mismo ID nuevo.

| Capacidad                                                 | Estado real                                                     | Siguiente acción                                                                  |
|-----------------------------------------------------------|-----------------------------------------------------------------|-----------------------------------------------------------------------------------|
| B02 en otros clones                                       | Supabase preparado; .env de cada clon no cambia por Git         | Configurar credencial runtime por canal privado y comprobar readiness/recorrido.  |
| Hosting HTTPS/B03                                         | Sin hosting público; guardas de código existentes               | Definir dominio/proxy y probar cookies Secure/HttpOnly/origen/recarga/logout.     |
| Rotación de cuentas anteriores                            | No realizada ni autorizada en este corte                        | Coordinar responsables y accesos sin alterar cuentas por iniciativa propia.       |
| Backup/recuperación/B06                                   | Reversión de URL preparada; restauración/caída/carga sin ensayo | Ensayo específico con respaldo y evidencia propia.                                |
| DELETE físicos, expiración natural y QA visual exhaustiva | No certificados                                                 | Entorno/autoridad adecuados y evidencia adicional; no tocar registros anteriores. |
| Juegos/voz/IA/WebRTC/firma/recuperación pública           | Fuera de esta corrección                                        | Conservar alcance previo; no atribuir persistencia nueva.                         |
| Pagos                                                     | Excluidos por profesor                                          | Sin implementación o nuevos commits de pagos.                                     |

## 06. Seguridad y riesgos priorizados

| Hallazgo                   | Estado y evidencia actual                                                                                                                     | Riesgo o límite                                                                              |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| B01 TLS                    | Conservado; cadena/nombre, TLS1.3 y confianza incorrecta rechazada con rol nuevo                                                              | CA2021 usa compatibilidad explícita de formato, no STRICT; conserva verificación.            |
| B02 permisos               | Aplicado/adoptado:58 políticas,22 tablas/16 secuencias; rol sin superuser, bypass, createdb, createrole, replicación, propiedad o pertenencia | USING true no aporta aislamiento por familia dentro de SQL. PUBLIC CONNECT/TEMP conservados. |
| B03 producción             | Parcial; guardas HTTPS/cookies/origen conservadas en pruebas unitarias                                                                        | Hosting HTTPS y rotación de cuentas anteriores pendientes.                                   |
| B04 abuso                  | Limitador local conservado y probado en unidades                                                                                              | Un proceso, sin coordinación de réplicas; reinicio borra estado.                             |
| B05 contratos              | Reglas compartidas conservadas;422 repetidos en ambas familias                                                                                | No todos los payloads ni migración de datos antiguos.                                        |
| B06 concurrencia/operación | Carrera y persistencia probadas en candidato y HTTP con rol nuevo                                                                             | Sin escritores externos, restauración, caída real ni cargas certificadas.                    |

Antes/después/final se compararon huellas de atributos de roles existentes, sus membresías anteriores, propietarios/RLS y ACL de otros destinatarios. Coincidieron; no se revocaron ni ampliaron privilegios de identidades anteriores. Se excluyen del cotejo solo entradas del rol nuevo y sus posibles membresías automáticas como rol concedido; el runtime no pertenece a otros roles. Las políticas anteriores se conservaron y solo se añadieron las aprobadas.

PUBLIC conserva CONNECT/TEMP en la BD y USAGE de public; no tiene grants de tablas/secuencias ni CREATE de BD/public. NOINHERIT no elimina derechos de PUBLIC; no se alteran defaults compartidos. Las dos funciones SECURITY DEFINER con EXECUTE público en graphql no son alcanzables por el runtime porque carece de USAGE del schema. Se comprobó ausencia de funciones definir alcanzables combinando ambos permisos. No afirmar una denegación absoluta de objetos temporales o de conexiones heredadas de PUBLIC.

Los seis rechazos42501 son: SELECT LIMIT0 de mensaje\_adjuntos, EXPLAIN sin ANALYZE de UPDATE/DELETE mensajes e INSERT roles, currval de secuencia logros no concedida y CREATE SCHEMA AUDITORIA\_B02\_DENIED. Cada probe usa savepoint revertido; la última no crea un objeto persistente. TRUNCATE/setval/ALTER sobre tablas clínicas no se ejecutan: sus privilegios/propiedad se verifican mediante catálogo. No se otorgó GRANT ALL ni acceso a funciones definir.

Solo DATABASE\_URL cambió en .env; el resto de claves y destino se cotejaron iguales. Respaldo y contraseña runtime permanecen en tmp ignorado. El propietario conserva sus permisos fuera del runtime. Reversión preparada a la URL previa; no se presenta como restauración de backup probada. Fuente/evidencia no incluyen URL, contraseña, SCRAM, token, cookie ni datos clínicos reales.

## 07. Evidencia, reproducción y límites

| Verificación                 | Resultado nuevo                                                                | Evidencia                                                                                |
|------------------------------|--------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|
| Revisión previa y aplicación | Rol no existente, RLS activa; transacción aplicada sin DML clínico             | preflight.json; application.json                                                         |
| Privilegios/denegaciones     | ACL exactas26 tablas/26 secuencias inspeccionadas;58 políticas;6 rechazos42501 | privileges-verification.json                                                             |
| Preservación                 | Snapshots originales y finales coinciden; solo DATABASE_URL cambió             | preservation-final.json; application.json                                                |
| Candidato / HTTP posterior   | 99 ASGI y133 HTTP registrados correctos                                        | candidate-journey.json; live-journey.json; live-followup.json; adoption-system.json      |
| Persistencia y PDF           | Cada cohorte:2/2/1/2 y0 sesiones auth nuevas activas; PDF sintético            | candidate-persistence.json; live-persistence.json; report-candidate.pdf; report-live.pdf |
| Conexión/modelos             | TLS válido/negativo,19 modelos sin diferencias;58 políticas                    | database-readonly.json                                                                   |
| Regresión seleccionada       | 114 pass,0 fail/skip,19 avisos; sin confest ni fixtures clínicas               | backend-unit.txt                                                                         |
| Fuentes y conocimiento       | Guiones compilados; AST local refresh/check, sin LLM                           | knowledge-refresh.txt; knowledge-check.txt                                               |
| Git/secretos/PDF             | V22 publicado; revisión de diff/secretos y páginas PDF                         | diagnostics.json; pdf-validation.json; manifest-sha256.json                              |

Comandos desde backend, para una futura ejecución expresamente autorizada: `python -m scripts.apply_b02_runtime_role --execute-authorized --output ../tmp/b02-application.json` (aborta si ya existe; no ejecutar en el rol runtime para reaplicar). Verificar: `python -m scripts.verify_b02_runtime_role --private ../tmp/b02-runtime-private.json --output ../tmp/b02-verification.json`. Candidato: `python -m scripts.verify_b02_journey --execute-authorized --private ../tmp/b02-runtime-private.json --output ../tmp/b02-candidate/journey.json`. Cada recorrido agrega una cohorte nueva; no sirve para comprobar solo health.

HTTP habitual: `python -m scripts.verify_hardening_journey --execute-authorized --output ../tmp/b02-live/journey.json`. Complemento: `python -m scripts.verify_hardening_followup --execute-authorized --source [journey] --private [archivo privado de cohorte] --output [followup]`. Persistencia: `python -m scripts.verify_hardening_persistence --source [journey] --output [persistence]`. Lectura TLS/modelos: `python -m scripts.verify_backend_readonly --output [readonly]`. Credenciales ADMIN bootstrap y runtime fuera de Git; no imprimirlas.

Unidades: `.venv313/Scripts/python.exe -m pytest --noconfest -p no:cacheprovider tests/test_backend_hardening.py tests/test_auth_api.py tests/test_auth_security.py tests/test_config_isolation.py tests/test_mensajeria.py tests/test_report_pdf.py tests/test_models.py -q`. Graphify: `python tools/knowledge/manage.py refresh` y `check` desde raíz. Nunca ejecutar confest destructivo o `ASHAKIDS_TEST_DATABASE_URL` contra Supabase compartido.

| Criterio visible del profesor | Evidencia nueva                                                                               | Límite                                                                      |
|-------------------------------|-----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|
| Arquitectura/backend          | ADR0010, separación de identidad técnica, contratos y API real                                | Sin rediseño de capas o hosting público.                                    |
| BD/modelo/operaciones         | Metadatos/RLS/grants reales y persistencia sintética                                          | Sin cambios estructurales ni DELETE físicos.                                |
| Seguridad y pruebas           | Rol mínimo por inventario, seis denegaciones, roles propios/ajenos, revocación y concurrencia | Sin pentest, carga, certificación clínica ni restauración. Rúbrica parcial. |

Evidencia heredada: corte13/backend83 y corte12/frontend94, incluidos257+25/tipos/build frontend. No son nuevas ejecuciones de este corte. Fallos de preparación: fetch markdown web no admitido y HTTP/CIM en sandbox denegados, resueltos por lecturas autorizadas; dos intentos de parche documental con contexto incorrecto no modificaron archivos y se corrigieron; sin fallos del recorrido funcional o SQL inesperado. Avisos deprecados conservados en log. No CI remoto observado.

## 08. Cierre y continuidad

V22/dd71407a8e21f0bacf6904bf430784d1c3b26dda publicado en dev y feat/piero-dev; rama local piero-dev. Informe/PDF14 e índice/contexto/progreso se incorporan en V23\_Auditoria\_BD\_Permisos\_Backend; comprobar SHA efectivo con Git al continuar. Versión de commit distinta de API0.1.0. El cambio de la BD compartida está aplicado; el push no cambia .env de otros clones.

Cohortes retenidas: candidato AUDITORIA13\_222612, usuarios62-66, pacientes91/92, tratamientos11/12, citas8/9, sesiones7/8, chat4; final AUDITORIA13\_222932, usuarios67-71, pacientes93/94, tratamientos13/14, citas10/11, sesiones9/10, chat5. El guion conserva prefijo13 por compatibilidad; ambos manifiestos pertenecen al corte14. Excluir de métricas clínicas y conservar sin borrar. No tocar cohortes anteriores. Los datos publicados son sintéticos.

Siguiente prioridad: configurar credencial runtime por canal privado en clones del equipo; después hosting HTTPS con proxy/cookies y ensayos autorizados de recuperación. La cuenta propietaria conserva permisos para administración y reversión. B02 de este clon está completado; B03/B06 mantienen pendientes concretos. No afirmar100%, hosting público, todas las pantallas o restauración verificada.

Referencias: CREATE ROLE PostgreSQL17 (<https://www.postgresql.org/docs/17/sql-createrole.html>), CREATE POLICY (<https://www.postgresql.org/docs/17/sql-createpolicy.html>), Contraseñas PostgreSQL (<https://www.postgresql.org/docs/17/auth-password.html>), Roles Supabase (<https://supabase.com/docs/guides/database/postgres/roles>), Conexión Supabase (<https://supabase.com/docs/guides/database/connecting-to-postgres>). Se consultó el changelog oficial; no se actualizó PostgreSQL ni extensiones en este corte.